Cerberus attack framework: what was added and how it is wired

Updated: 2 November 2026 (Cairo) · Project commit `59dc2b7` on top of `bf543af`

> **Authorization first.** Test only systems you own or have written permission to test, and only with tools the system's operator allows. Every module checks scope before it runs, but those checks do not replace permission.

1. What the framework contains

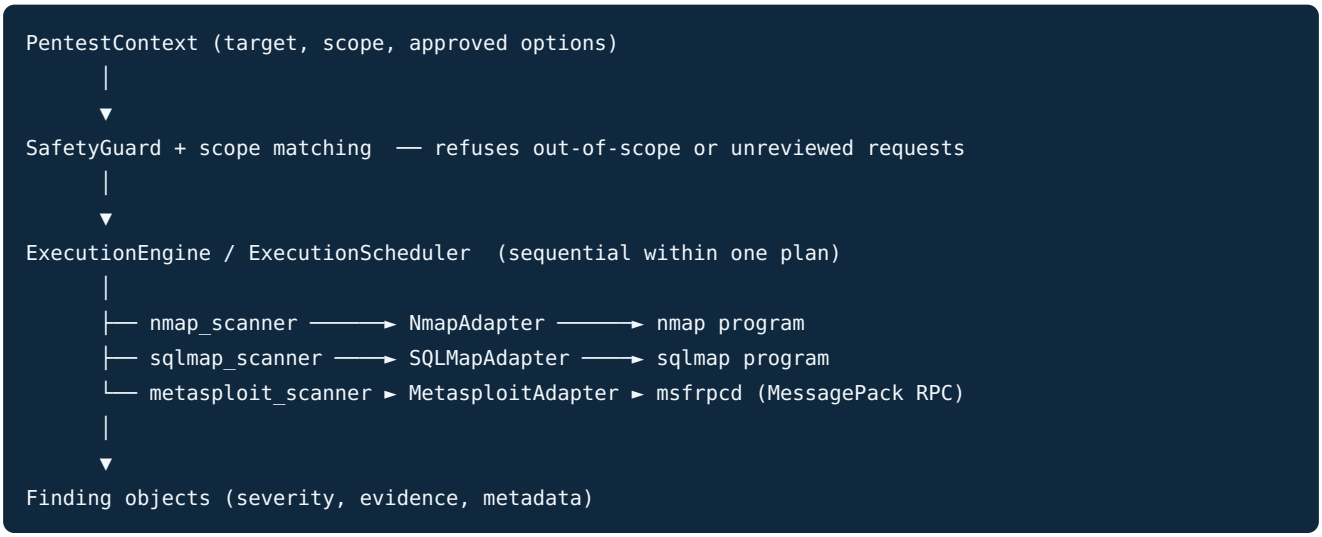
The framework has two parts.

Attack modules (9). These run inside the Cerberus backend, under `backend/app/ai_engine/pentest/modules/`:

Module	Folder	What it does
`port_scanner`	network	Basic TCP port check
`service_fingerprint`	network	Identifies services on open ports
`credential_tester`	auth	Credential checks, limited to approved scope
`sqli_probe`	web	SQL injection probe (built-in)
`xss_probe`	web	Reflected XSS probe. Findings are **candidates** unless verified.
`path_traversal_probe`	web	Path traversal probe (built-in)
`nmap_scanner`	tools	Runs the real Nmap program
`sqlmap_scanner`	tools	Runs the real sqlmap program
`metasploit_scanner`	tools	Runs the real Metasploit program through `msfrpcd`

External tool adapters (3). These connect the framework to the three programs: `nmap`, `sqlmap` and `metasploit`. Each adapter is discovered automatically by `default_tool_registry()`.

2. How the pieces connect



- **Sequential within one plan.** The scheduler runs modules one after another. Separate engagements can run at the same time.
- **Nmap results are shared, not handed over.** Nmap's open ports are stored in the context, but Metasploit does not use them automatically. This automatic handoff is not implemented.
- **API and AI agent are not connected yet.** The app's interface and AI agent do not start these modules. That is a later phase.

3. Safety rules that are enforced in code

- **Metasploit:** only the reviewed `auxiliary/scanner/portscan/tcp` module can run. Other auxiliary and exploit modules are refused, including at FULL impact. Ports must be approved and bounded by `PENTEST_MAX_PORTS`.
- **Nmap:** NSE scripts are limited to `banner` and `ssl-cert`. Wildcards and categories are refused.
- **sqlmap:** one approved URL per run. Risk is fixed at 1. Levels above 1 and POST requests need at least `limited` impact.
- **Scope matching:** checks host, scheme, path and port, not substrings. Wildcard exclusions are refused.
- **Testing window:** if `testing_window` is set, every module refuses to run. The framework does not enforce it yet.

4. Public targets: what is permitted

Only use a public site for a tool its operator allows. This table is the project record.

Site	Tool used	Permission	Status
`scanme.nmap.org`	Nmap only	Operator allows Nmap scans (about 12 per day), no exploits or denial of service	Captured 2026-10-28 (01:53 UTC): ports 22, 80, 443 open
`sekumart.sekuripy.hr`, product `id` parameter	sqlmap only	Operator's public SQL injection practice site	Captured 2026-10-28 (01:53 UTC): error-based injection in GET `id`
Metasploit	Metasploit	No public site permits it	**Not tested publicly.** Tested only on loopback.

Site	Tool used	Permission	Status
`demo.testfire.net`	—	Not used. An older guide listed it, but no permission for these tools is recorded here.	Do not use for these tests until its terms are checked.

5. Verification status

Check	Result (as recorded)
Pentest unit tests, no database (`--noconftest`)	**228 passed**, 2 deselected (database persistence tests)
Full backend suite, 2 Nov 2026 (rebuilt environment, PostgreSQL and Redis on throwaway instances)	**385 passed.** An isolation fix was added to `backend/tests/conftest.py`: the test run now clears only `abuse:*` Redis counters between tests.
Beginner lab (`nmap`, `sqlmap`, `all`, `parallel`) on a local lab	PASS with real Nmap and real sqlmap. Metasploit is simulated.
sqlmap smoke test, local lab	PASS: GET and form POST injection, controls, redirects, two concurrent scans
Metasploit 6.5.9 real `msfrpcd`, loopback only	PASS on 2 Nov 2026 with a newer package build: IPv4 and IPv6 open ports found, out-of-scope target refused, exploit module refused. Earlier combined run with real Nmap and sqlmap also passed.
Public Nmap and sqlmap	Captured 2026-10-28 (see section 4). Not repeated in this update.

6. Known limits

- Metasploit has no public test result. Its only real test is on loopback.
- No automatic Nmap-to-Metasploit handoff.
- Testing window is not enforced. The legal testing period is not loaded automatically.
- Ordinary DNS names are not pinned to IP addresses.
- Background jobs and dependency advisories still need separate review.
- Mac and Windows install commands were written for those systems but have not been run on them.
- The framework is **not production-ready.**

7. Where to find each tool's files

- Metasploit: `Metasploit/`
- Nmap: `Nmap/`
- sqlmap: `sqlmap/`
- Beginner commands for all tools: `Beginner guide/`
- Real captured results (public, local and simulated are labelled separately): `Real results/`
- Terminal verification steps: `VS Code terminal/`